SUPPORT ÉTUDIANT

DSP2 et Open Banking

Jour 4 : L'agrégation de comptes

Chrisvene MPANDZOU

chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Sommaire

Repères de lecture du polycopié

01 Introduction & objectifs 3

02 S1 · Principe de l'agrégation 4

03 S2 · Flux AIS & consentement 8

04 S3 · Architecture SI AISP 13

05 S4 · Sécurité & gouvernance 18

Introduction & objectifs

ACCUEIL

Intro & objectifs

Le Jour 3 a fait *écrire* de l'argent (le PISP). Le Jour 4 fait *lire* l'argent : le tiers agrège les comptes du client, avec son consentement, pour en tirer un service — du récapitulatif de budget au scoring de crédit.

FIL ROUGE

Lyam a deux comptes : Banque Est et une néobanque. Il installe **MonBuddy**, l'application de gestion de budget. Cette fois, plus d'identifiants à saisir : il choisit ses banques, donne un consentement daté, et voit tous ses soldes au même endroit. Ce que la DSP2 a rendu possible, contre le *screen scraping* du Jour 1.

RAPPEL

Là où l'on en est

Au Jour 1, on a posé les trois rôles de tiers : **AISP** (lecture), **PISP** (initiation), **CBPII** (confirmation de fonds). Au Jour 2, on a vu l'authentification (mTLS, OAuth2) et le consentement. Au Jour 3, on a fait un paiement (PISP). On attaque maintenant le rôle *le plus utilisé* et le plus sous-estimé : la lecture de comptes.

Pourquoi l'AIS est « la porte d'entrée »

L'AIS ne déplace pas d'argent : une erreur lit simplement un mauvais solde. Mais c'est **le service le plus répandu** (budget, agrégation, scoring, onboarding, KYC) et le plus exposé à la donnée personnelle. C'est donc le terrain idéal pour parler de consentement, de minimisation et de gouvernance de la donnée — le *data banking*.

APERÇU

Le parcours du Jour 4, en une image

On part du principe de l'agrégation (lire plusieurs banques), on suit le consentement AIS et son cycle de vie, on descend dans l'architecture d'un agrégateur, puis on conçoit un service de data banking en atelier.

S1 — Principe de l'agrégation

Qu'est-ce qu'un AISP ? Lire un compte, agréger plusieurs banques, le tiers détenteur de données. AIS vs scraping.

S2 — Flux AIS & consentement

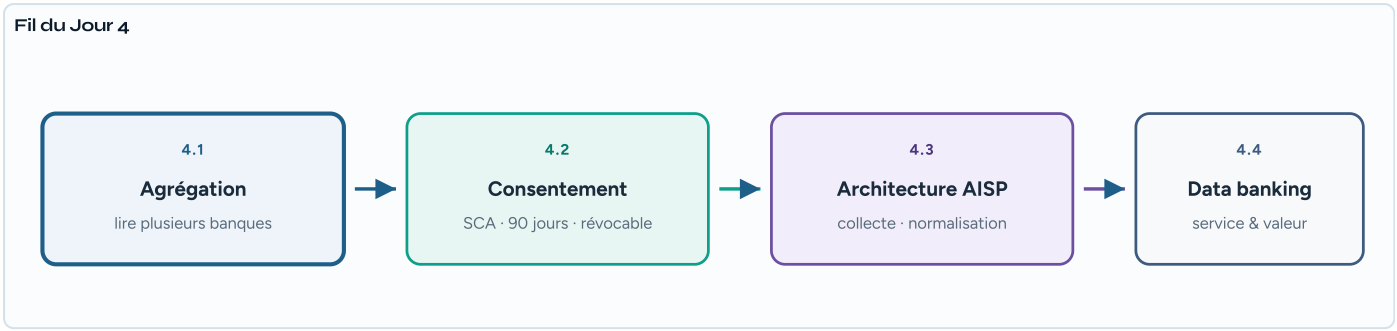
Création du consentement, SCA initiale, lecture des soldes et transactions, raffraîchissements, durée (90 jours), révocation.

S3 — Architecture SI AISP

Collecteurs multi-banques, normalisation, stockage, API exposée. Contraintes : volumétrie, fraîcheur, sécurité de la donnée.

S4 — Atelier data banking

Concevoir un service fondé sur la donnée de compte : parcours, consentement, données lues, valeur produite.



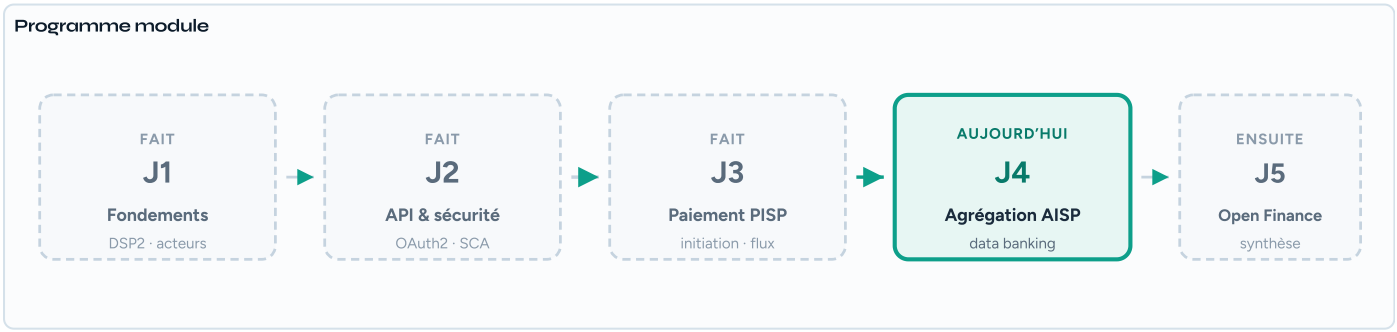
OBJECTIFS PÉDAGOGIQUES

À l'issue du Jour 4, l'étudiant sait…

- **Définir** un service d'information sur les comptes (AIS) : la lecture de comptes du client par un tiers agréé, avec son consentement, sans les identifiants.
- **Expliquer** l'agrégation multi-banques : pourquoi un tiers collecte plusieurs ASPSP et ce qu'il doit normaliser.
- **Décrire** le cycle de vie d'un consentement AIS : création, SCA, lecture, fréquence, durée (90 jours), révocation.
- **Cartographier** l'architecture SI d'un AISP : collecteurs, normalisation, stockage, API exposée, et leurs contraintes (volumétrie, fraîcheur, sécurité).
- **Distinguer** donnée brute et donnée enrichie : catégorisation, scoring, restituer de la valeur au client.
- **Concevoir** un service de data banking dans le respect du consentement, de la minimisation et du RGPD.

CURSUS

Trajectoire des 5 jours



02 · S1 · PRINCIPE DE L'AGRÉGATION

S1 - Principe de l'agrégation

QU'EST-CE QU'UN TIERS AGRÉGATEUR ?

Principe de l'agrégation

Lire les comptes du client, chez plusieurs banques, avec son consentement. On définit le rôle AISP, on montre ce que « agréger » ajoute à une simple lecture, et en quoi cela change tout par rapport au *screen scraping*.

FIL ROUGE

Lyam ouvre **MonBuddy**. L'application lui demande *quelles banques* elle veut connecter. Elle coche Banque Est et sa néobanque. Elle s'authentifie chez chacune, valide un consentement, et revient sur MonBuddy : ses deux soldes s'affichent. **Aucun identifiant n'a été transmis à MonBuddy.**

DÉFINITION

L'AIS, mot à mot

> **Service d'information sur les comptes** (en anglais *Account Information Service*, AIS) : service en ligne consistant à fournir des **informations consolidées** sur un ou plusieurs comptes de paiement du client, détenus chez différents établissements, **avec le consentement explicite du client** et via les **interfaces dédiées** des banques.

Trois mots portent le sens :

« Informations »

L'AIS **lit** seulement : soldes, opérations, libellés. Il ne déclenche **aucun paiement**. C'est la différence de nature avec le PISP du Jour 3.

« Consolidées »

La valeur vient de l'**agrégation** : réunir plusieurs banques en une vue. Un seul compte, c'est une appli bancaire ; plusieurs, c'est un service.

« Consentement »

Le client **autorise explicitement**, pour une durée bornée, une liste de comptes et de données. Révocable à tout moment.

AIS ≠ consultation d'un compte isolé

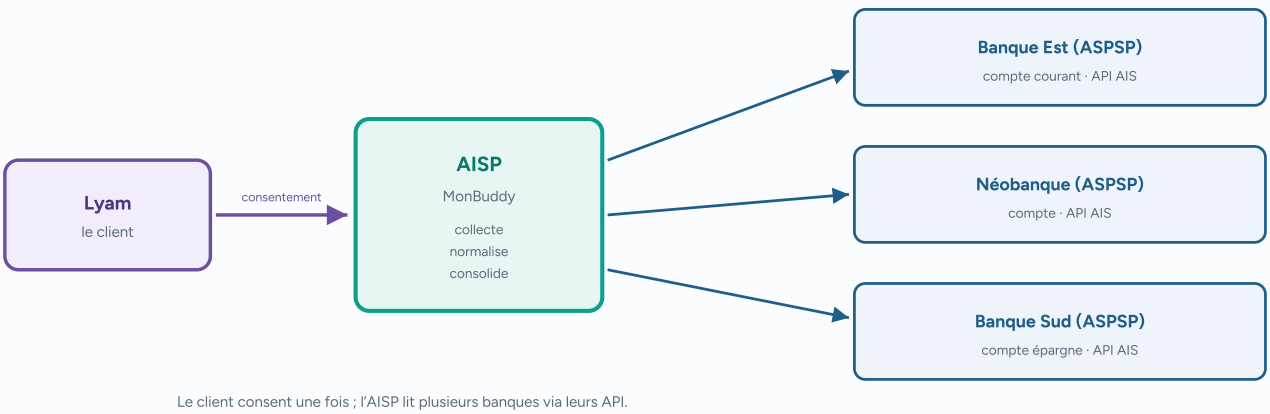
La lecture d'un compte par l'appli de *sa propre* banque n'est pas un service AIS : c'est l'ASPSP lui-même. L'AIS commence quand un **tiers** lit les comptes du client, chez **une ou plusieurs banques**, sur autorisation. C'est cette délégation encadrée que la DSP2 a créée.

MÉCANIQUE

Agréger : lire plusieurs banques en une vue

Agréger, c'est interroger plusieurs banques et présenter un résultat unique. Le tiers devient un **point de collecte** : une seule application, plusieurs sources.

Agrégation multi-banques



Le client consent une fois ; l'AISP lit plusieurs banques via leurs API.

IDÉE DIRECTRICE

L'AISP ne détient pas d'argent et ne modifie rien : il *collecte* de la donnée, la *normalise* et la *consolide*. Sa valeur, c'est la vue unique — et la confiance du client qui a donné son consentement.

Ne pas confondre AISP et agrégateur « historique »

Avant la DSP2, des agrégateurs lisaient déjà plusieurs banques — mais par *screen scraping*, avec les identifiants du client. L'AISP DSP2 fait la même chose **en mieux** : API officielle, consentement, SCA, révocation, traçabilité. La finalité est proche ; le *moyen* est radicalement plus sûr.

POSITIONNEMENT

AIS vs screen scraping

La comparaison avec le scraping du Jour 1 est le meilleur moyen de mesurer l'apport de la DSP2 côté lecture.

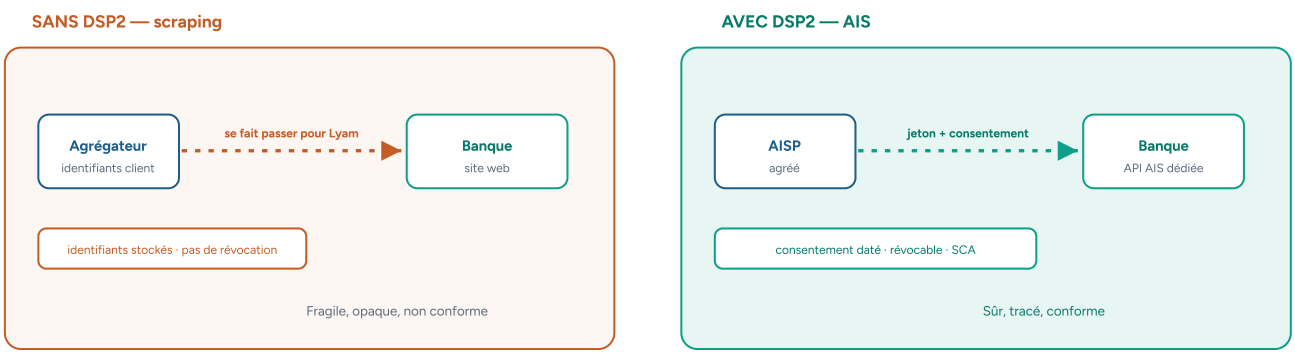


Figure — le même besoin (voir plusieurs comptes), deux moyens : l'usurpation (avant) ou l'API consentie (après).

CRITÈRE	SCREEN SCRAPING	AIS (DSP2)
Accès	Interface web détournée	API dédiée officielle
Identifiants	Stockés par le tiers	Jamais transmis au tiers
SCA	Contournée	Obligatoire au consentement
Révocation	Changer ses codes	Un clic, côté banque ou tiers
Traçabilité	Nulle	Journalisée, auditables
Conformité	**Interdit depuis 2019**	**Cadre DSP2 + RGPD**

RATIONNEL

Pourquoi l'AIS existe ?

La DSP2 poursuit trois objectifs (Jour 1 : concurrence, innovation, protection). L'AIS les incarne côté *donnée* :

01

Concurrence

> *« Pourquoi une seule appli pour voir mes comptes, celle de ma banque ? »*

L'AIS permet à des tiers de proposer de la gestion de compte consolidée, en concurrence avec l'appli bancaire.

02

Innovation

> *« Je veux catégoriser mes dépenses, anticiper mon découvert, comparer mes offres. »*

Sur la donnée de compte se construisent budget, scoring de crédit, onboarding, comparateurs — le *data banking*.

03

Protection

> *« Le tiers ne verra jamais mes codes, et je peux couper l'accès quand je veux. »*

Consentement explicite, SCA, durée bornée, révocation : le client garde le contrôle de sa donnée.

Les limites réelles de l'AIS

L'AIS dépend de la **disponibilité des API** de chaque banque : une lecture peut échouer. La **fraîcheur** des données n'est pas temps réel (rafraîchissements plafonnés). Et la **qualité des libellés** varie d'une banque à l'autre : normaliser est tout un métier. Un agrégateur doit composer avec ces trois limites.

COURS — AIS, CBPII : NE PAS CONFONDRE LES DEUX « LECTURES »

SERVICE	CE QU'IL FAIT	DONNÉE EXPOSÉE
AIS	Fournit des informations consolidées sur les comptes	Soldes, transactions, libellés
CBPII	**Confirme à un tiers si le compte dispose des fonds pour un paiement**	**Un simple *oui/non* sur la provision**

Le CBPII ne lit pas l'historique : il répond à une question « y a-t-il assez d'argent ? ». L'AIS lit la donnée dans le détail. Les deux sont des services de *lecture*, mais ne livrent pas la même information — et n'ont pas le même périmètre de consentement.

SÉQUENCE SUIVANTE

Lisons, concrètement

On sait ce qu'est l'agrégation. La S2 suit le consentement dans le temps : sa création par SCA, les lectures autorisées, les rafraîchissements, la durée de 90 jours et la révocation.

S2 - Flux AIS & consentement

DU CONSENTEMENT À LA REVUE DES COMPTES

Flux AIS & consentement

Un consentement AIS a un cycle de vie : on le crée par SCA, on lit les comptes qu'il couvre, on rafraîchit selon des règles, et on peut le révoquer. On suit ce cycle du début à la fin.

FIL ROUGE

Lyam a connecté Banque Est et sa néobanque. Il a validé deux authentifications fortes. Pendant 90 jours, MonBuddy pourra lire ses soldes et opérations — puis il faudra reconfirmer. Et si Lyam retire son consentement, l'accès s'arrête net.

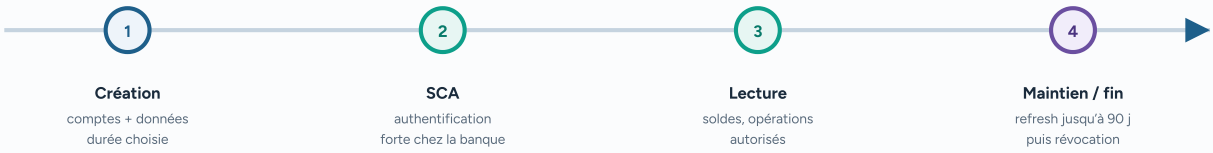
VUE D'ENSEMBLE

Le cycle de vie en quatre temps

L'AIS a un rythme : une fois mis en place, il vit et meurt. Quatre moments structurent ce cycle.

#	ÉTAPE	ACTEUR PRINCIPAL	RÉSULTAT
1	Création du consentement	AISP + client	Contrat de lecture : comptes, données, durée
2	SCA & autorisation	Banque (ASPSP)	Jeton d'accès accordé à l'AISP
3	Lecture des comptes	AISP	Soldes et transactions récupérés
4	**Rafraîchissement & révocation**	**AISP / client**	**Donnée à jour, ou accès coupé**

Cycle de vie du consentement AIS



ÉTAPE 1

Le consentement : un contrat de lecture

Le consentement AIS n'est pas un « ok » vague : c'est une autorisation **délimitée**. Il dit *quels comptes*, *quelles données*, *pendant combien de temps*, et *pour quelle finalité*.

Ce que précise un consentement AIS

- **Comptes** couverts (un, plusieurs ou « tous ») ;
- **Données** : soldes, opérations, bénéficiaires, etc. ;
- **Fréquence** d'accès (rafraîchissements autorisés) ;
- **Durée** (typiquement jusqu'à 90 jours, reconductible par re-SCA) ;
- **Finalité** au sens RGPD, et révocabilité à tout moment.

1 **Sélection des comptes**

MonBuddy propose à Lyam de choisir ses banques. Chaque banque sera interrogée séparément.

2 **Consentement explicite**

Lyam valide une liste de données et une durée. Ce n'est pas une case pré-cochée : c'est un acte positif, lisible.

3 **Information RGPD**

Finalité, minimisation, durée de conservation côté AISP. Le consentement DSP2 doit aussi tenir debout face au RGPD (Jour 1).

ÉTAPE 2

La SCA : l'autorisation chez la banque

Comme pour le PISP, c'est la **banque (ASPSP)** qui authentifie fortement le client et délivre l'accès. L'AISP ne collecte jamais les secrets : il obtient un **jeton** lié au consentement.

Ce que fait la banque

- Affiche le consentement (comptes, données, durée) ;
- Réalise la SCA (code, push, biométrie) ;
- Émet un jeton d'accès à durée courte, renouvelable ;
- Conserve la preuve de la SCA pour l'audit.

Ce que fait l'AISP

- Redirige vers la banque (redirection SCA) ;
- Stocke le jeton, jamais les identifiants ;
- Utilise le jeton pour lire les comptes ;
- Le renouvelle selon les règles de la banque.

Le jeton n'est pas un chèque en blanc

Le jeton AIS n'autorise que la **lecture** des comptes couverts par *ce* consentement. Il ne permet pas d'initier un paiement (ça, c'est le PISP), et il expire. Un jeton volé sans le consentement associé ne sert à rien — c'est tout l'intérêt du modèle.

ÉTAPE 3

La lecture des comptes

L'AISP appelle les endpoints AIS : liste des comptes, soldes, transactions. Chaque appel est authentifié par le jeton. On lit *uniquement* ce que le consentement couvre.

EXEMPLE — LECTURE DES COMPTES ET TRANSACTIONS (ILLUSTRATIF)

```
GET /v1/accounts
Authorization: Bearer eyJhbGciOi...
Consent-ID: 7d2a-consentement-8823

GET /v1/accounts/{account-id}/balances
Authorization: Bearer eyJhbGciOi...

GET /v1/accounts/{account-id}/transactions?dateFrom=2025-01-01
Authorization: Bearer eyJhbGciOi...
```

RESSOURCE AIS	CONTENU	USAGE TYPE
Comptes	IBAN masqué, type, titulaire	Afficher les comptes agrégés
Soldes	Solde comptable, disponible	Vue consolidée
Transactions	Date, montant, libellé, contrepartie	Budget, catégorisation, scoring
Bénéficiaires	**Liste des bénéficiaires enregistrés**	**Pré-remplissage, anti-fraude**

La qualité des libellés

Un libellé « CB CARREFOUR 12/03 » chez une banque peut être « PAIEMENT CARTE » chez une autre. **Normaliser** et **catégoriser** sont l'essentiel du travail d'un agrégateur : sans ça, la donnée consolidée est inutilisable.

ÉTAPE 4

Rafraîchissement et révocation

Le consentement vit : il faut rafraîchir la donnée, sans marteler l'API de la banque, et pouvoir l'arrêter.

01

Rafraîchissement

> *« Mon solde doit être à jour : je ne peux pas lire l'ancien. »*

Les RTS encadrent la fréquence : par exemple, pas de rafraîchissement automatique plus d'une fois par jour sans nouvelle SCA. L'AISP doit respecter ces règles.

02

Durée

> *« Mon consentement va durer combien de temps ? »*

Jusqu'à 90 jours : au-delà, l'AISP doit obtenir une nouvelle SCA (re-consentement). C'est un garde-fou qui oblige à revoir la délégation.

03

Révocation

> *« Je ne veux plus que MonBuddy lise mes comptes, tout de suite. »*

Le client peut révoquer côté banque ou côté AISP. Le jeton devient invalide : plus aucune lecture n'est possible, sans changer ses identifiants.

La révocation n'efface pas tout

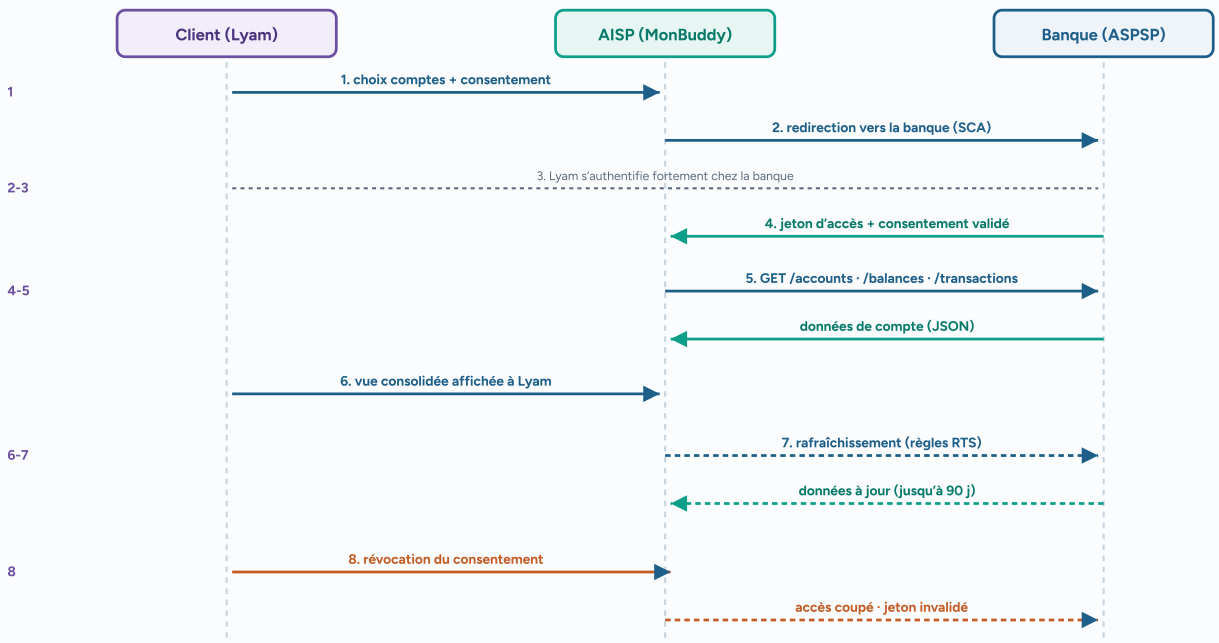
Couper l'accès stoppe les *lectures futures*. Mais les données déjà collectées ? Le RGPD impose des durées de conservation et un droit à l'effacement. Révoquer côté DSP2 ne supprime pas magiquement l'historique stocké côté AISP : ce sont deux mécanismes distincts, à expliquer clairement au client.

SYNTHÈSE

Le flux complet en un diagramme

Création, SCA, lecture, rafraîchissement et révocation : les acteurs et les messages qui font vivre un consentement AIS.

Diagramme de séquence — consentement AIS



Rafraîchir n'est pas interroger

Une implémentation naïve appelle l'API de la banque à chaque affichage d'écran. C'est coûteux, lent, et interdit par les RTS au-delà des seuils. Un AISP mature **met en cache**, rafraîchit selon les règles, et sert la donnée stockée le reste du temps.

COMPARAISON

AIS vs PISP : même socle, deux pouvoirs

L'AIS et le PISP partagent la sécurité du Jour 2 mais ne donnent pas le même pouvoir. Cette grille fixe la

distinction.

CRITÈRE	AIS	PISP
Action	Lit	Écrit (initie un virement)
Consentement	Récurrent, jusqu'à 90 j	Un paiement = un consentement
SCA	Au consentement, puis refresh encadré	À chaque paiement
Impact d'erreur	Mauvais affichage	Argent déplacé
Idempotence	**Utile (lectures doublées)**	**Critique (double débit)**

Un même tiers peut-il être les deux ?

Oui : un établissement peut détenir les deux agréments. Mais chaque opération relève d'un rôle, d'un consentement et d'un jeton distincts. Un consentement AIS ne permet **jamais** d'initier un paiement — la séparation est au cœur de la sécurité du modèle.

RÉALITÉ TERRAIN

Les trois problèmes que l'on découvre en production

Sur le papier, le flux AIS tient en cinq étapes. En production, un agrégateur affronte trois difficultés qui ne figurent dans aucun schéma : garder la donnée **fraîche**, la rendre **comparable**, et survivre à des API bancaires qui ne répondent pas toujours.

Problème 1 — Synchronisation : quelle est la fraîcheur de ce que j'affiche ?

Une API AIS ne « pousse » pas les transactions. Le TPP doit décider quand relire : trop souvent, la banque limite ; trop rarement, l'utilisateur voit un solde faux. Il y a deux stratégies et un piège.

- **Polling** — le TPP interroge à intervalles fixes. Simple, mais coûteux et soumis aux quotas de la banque (souvent 4 lectures par jour et par compte).
- **Webhooks** (quand la banque en propose) — la banque notifie la disponibilité de nouvelles données. Plus réactif, mais peu généralisé et jamais garanti.
- **Le piège** — afficher un solde sans dire sa date. Un utilisateur qui voit « 340,20 € » à midi alors que la dernière lecture date de la veille prend une décision sur une donnée périmée.

La pratique : horodater chaque lecture, exposer la date à l'utilisateur, et définir une règle de fraîcheur par type de donnée — un solde tolère quelques heures, une opération récente non.

Problème 2 — Qualité des données : deux banques, deux vérités

Rien ne garantit l'homogénéité entre établissements. Le même virement peut arriver avec un libellé différent, une date différente (opération vs valeur) et un format de montant différent.

- **Libellés SEPA sales** — un libellé ressemble rarement à « Loyer ». Il ressemble à `VIR SEPA 4471 LEROY IMMO REF`. Catégoriser suppose un moteur de règles.
- **Dates multiples** — date d'opération, date de valeur, date de comptabilisation : un même mouvement peut apparaître trois fois si l'on ne choisit pas une référence unique.
- **Doublons et chevauchements** — entre deux lectures, une opération peut être renvoyée deux fois : sans identifiant stable côté banque, la déduplication devient heuristique.
- **Devises et arrondis** — un compte en devise étrangère impose un taux et une date de conversion ; agréger naïvement des montants de devises différentes est faux.

Problème 3 — Disponibilité de l'API : la banque n'est pas à vous

Les interface ASPSP tombent, rament, ou renvoient des erreurs transitoires. Le TPP ne contrôle ni leur disponibilité ni leur latence — il ne peut que s'y adapter proprement.

- **Codes de limitation** — `429` et `Retry-After` : rejouer immédiatement aggrave la situation. Il faut un backoff exponentiel avec jitter.
- **Disjoncteur (circuit breaker)** — après N échecs consécutifs sur une banque, on cesse de l'appeler quelques minutes plutôt que d'empiler les timeouts.
- **Dégradation** — afficher les dernières données connues avec leur date, plutôt qu'une erreur. Un service qui dit « voici l'état d'il y a 3 h » reste utile.
- **Cohérence multi-banques** — si la Banque A répond et la Banque B non, faut-il afficher une vue partielle ? Oui, à condition de le dire *banque par banque*.

SÉQUENCE SUIVANTE

Comment on industrialise tout ça ?

Le consentement et la lecture sont posés. La S3 ouvre la boîte de l'AISP : collecteurs multi-banques, normalisation, stockage, API exposée, et les contraintes de volumétrie, de fraîcheur et de sécurité de la donnée.

04 · S3 · ARCHITECTURE SI AISP

S3 - Architecture SI AISP

LA MACHINE QUI AGRÈGE ET SERT LA DONNÉE

Architecture SI AISP

Un agrégateur, c'est une usine à donnée : collecter chez plusieurs banques, normaliser, stocker, servir. On pose les composants, puis les contraintes qui décident si le service tient en production.

FIL ROUGE

Lyam voit une simple vue de ses deux comptes. Derrière, MonBuddy interroge deux banques, transforme leurs formats différents en un modèle unique, stocke l'historique, et répond à l'écran en quelques dizaines de millisecondes. Cette séquence ouvre **la boîte de l'AISP**.

COMPOSANTS

Les quatre briques d'un AISP

L'agrégateur se décompose en quatre composants. Chacun a une responsabilité propre ; les confondre est l'erreur d'architecture la plus fréquente.

1

Collecteurs multi-banques

Un **connecteur par banque** : un pour le format de Banque Est, un pour la néobanque, etc. Il gère l'authentification, les appels AIS, les retries, les quotas. C'est l'*adaptateur* entre chaque ASPSP et l'intérieur.

2

Normalisation

Transformer les données hétérogènes en un modèle commun : montant, devise, date, contrepartie, direction. C'est ici que l'on catégorise les libellés et qu'on lisse les différences entre banques.

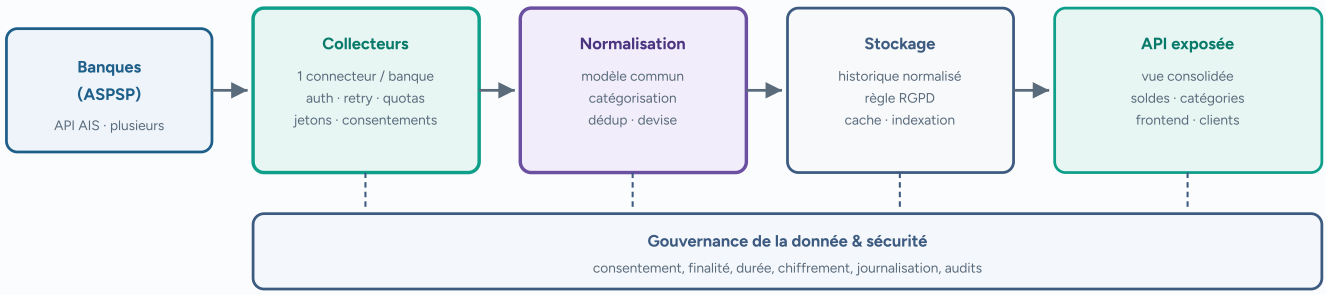
3 Stockage

Conserver l'historique normalisé, avec la durée et les règles RGPD. Permet les lectures rapides, les tendances, et le service même quand une banque est momentanément indisponible.

4 API exposée

Le **point de service** vers le frontend ou les clients de l'AISP : vue consolidée, soldes, catégories. C'est ce que consomme l'application de Lyam.

Chaîne AISP de bout en bout



Où se trouve le consentement ?

Le consentement n'est pas un composant isolé : il **traverse** la chaîne. Les collecteurs le matérialisent (jeton), la normalisation le respecte (on ne garde que ce qu'il couvre), le stockage le porte (durée), l'API exposée ne sert que ce qu'il autorise. Un AISP qui « oublie » le consentement en aval est un AISP en infraction.

CONTRAINTES

Les trois tensions de l'AISP

Une architecture AISP vit sous trois tensions permanentes. Le métier est de les arbitrer, pas de les ignorer.

Volumétrie

Des millions de comptes × des dizaines d'opérations/mois × plusieurs banques. On ne peut pas tout lire en temps réel : il faut **batcher**, **cacher** et **indexer**.

Fraîcheur

La donnée n'est jamais « temps réel » : elle est aussi fraîche que le dernier rafraîchissement autorisé (S2). L'interface doit dire *quand* elle a été rafraîchie.

Sécurité de la donnée

La donnée de compte est sensible : **chiffrement**, **cloisonnement** par client, **journalisation** des accès, minimisation.

La disponibilité des banques fait la qualité de service

Un AISP ne contrôle pas les API de ses banques. Une banque lente ou indisponible dégrade le service global. D'où plusieurs réflexes d'architecture : **circuit breaker** par banque (isoler la panne d'une source), **cache** (servir la dernière donnée connue), **file d'attente** pour rejouer les lectures, et **health-checks** par connecteur. Sans ça, une banque en panne fait tomber toute la vue consolidée.

1. **Circuit breaker par banque**
   Si Banque Est échoue 3 fois, on l'isole temporairement : la néobanque continue à s'afficher.

2. **Cache avec date de fraîcheur**
   On sert la dernière donnée connue en indiquant son horodatage, plutôt qu'une erreur.

3. **File de rejeu idempotente**
   Une lecture en échec est rejouée sans dupliquer les opérations : la déduplication par identifiant de transaction évite les doublons.

4. **Observabilité**
   Métriques par connecteur (latence, taux d'erreur), alertes, traces : on sait quelle banque dégrade le service.

DIMENSIONNEMENT

Un ordre de grandeur, pas une formule

Une question revient toujours en entretien : « ça tient combien de clients ? » On ne donne pas un chiffre magique, on raisonne en tension.

AXE	QUESTION	CONSÉQUENCE D'ARCHITECTURE
Comptes	Combien de comptes lus, combien de banques ?	Nombre de connecteurs, volumétrie de stockage
Fréquence	Combien de rafraîchissements/jour autorisés ?	Charge API, files, cache
Historique	Combien de mois/années conservés ?	Stockage, indexation, purge RGPD
Latence	**Objectif d'affichage de la vue consolidée ?**	**Cache lecture, pré-agrégation**

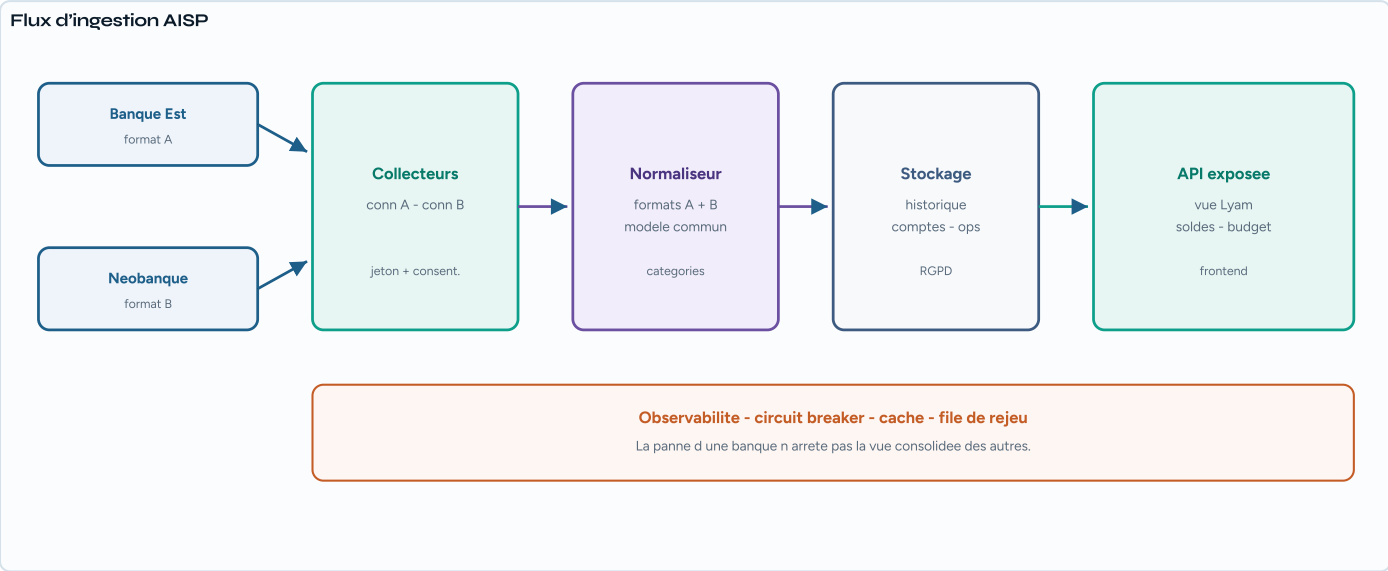
La pré-agrégation, ou le bon compromis latence/coût

Pour la vue « budget du mois », inutile de recalculer à chaque clic : on **précalcule** les agrégats (totaux par catégorie) au rafraîchissement, et on les sert instantanément. C'est la même logique que le cache du PISP du Jour 3 : ne pas refaire inutilement ce qui n'a pas changé.

SYNTHÈSE

Un flux d'ingestion, plusieurs banques

Le même scénario Lyam : deux banques, deux formats, une donnée normalisée, un écran.



Le piege de la base unique

Melanger collecte, normalisation et exposition dans un seul service fait un monolithe ingerable : on ne peut plus ajouter une banque sans tout redeployer, ni isoler une panne. Separer les quatre composants rend l ensemble extensible : chaque nouvelle banque est un nouveau connecteur, sans toucher au reste.

NOTIONS

À qui appartient la donnée ?

L'AISP lit, copie et transforme. La question « à qui est la donnée ? » n'a pas de réponse binaire : elle se décompose en trois droits distincts, souvent confondus.

DROIT	QUI LE DÉTIENT	CE QUE ÇA IMPLIQUE CONCRÈTEMENT
Propriété de la donnée	Le client	Ses opérations lui appartiennent, pas à la banque ni à l'AISP
Garde de l'original	La banque (ASPSP)	Elle est la source de vérité, et doit la fournir sur demande du client
Droit d'usage	L'AISP, pour la finalité consentie	Limité dans le temps, dans la portée et dans l'usage
Droit de reprise	**Le client, à tout moment**	**Export de ses données dans un format exploitable**

La conséquence pour un AISP

Un AISP n'est pas *propriétaire* des données qu'il agrège : il en est le **dépositaire temporaire**, avec un mandat précis. Toute réutilisation hors de ce mandat — enrichissement, revente, profilage non consenti — est une faute, même si elle est techniquement triviale.

NOTIONS

Portabilité : le droit de partir

La portabilité est la traduction opérationnelle du droit de reprise. Un client qui change d'appli doit pouvoir emporter son historique — sans que l'AISP sortant n'invente de blocage technique.

1. **Export dans un format structuré**
   Machine-lisible et documenté (CSV à schéma défini, JSON, ISO 20022 si possible). Un capture d'écran n'est pas un export.
2. **Complétude et intégrité**
   L'export doit couvrir tout l'historique conservé, pas un échantillon. Une synthèse partielle vide le droit de son sens.
3. **Délai et gratuité**
   Le RGPD impose une réponse dans un délai d'un mois. Un export payant ou retardé est un frein dissuasif, pas un service.
4. **Sortie propre**
   Après export, l'AISP reste soumis à sa politique de conservation pour les copies : la portabilité ne l'autorise pas à tout effacer de manière anticipée s'il a une obligation légale de conserver.

Le piège du « lock-in » déguisé

Un export au format maison, non documenté, qui ne réimporte nulle part : techniquement un export, en pratique un rempart. C'est le contournement le plus courant du droit de portabilité.

NOTIONS

Traçabilité : savoir qui a lu quoi

La traçabilité n'est pas un luxe d'auditeur : c'est l'instrument qui permet de *détecter* une lecture anormale, et — en cas de réclamation — de **répondre** au client sur ce qui a été consulté.

Ce qu'elle couvre

Chaque appel d'API est relié à un consentement, un compte, un horodatage et un appelant. On peut reconstituer un historique complet d'accès, pas seulement d'erreurs.

Ce qu'elle ne couvre pas

La trace ne dit pas pourquoi une donnée a été lue, ni si l'usage était légitime. Elle documente l'accès, elle ne qualifie pas l'intention : la gouvernance reste humaine.

ÉVÉNEMENT	POURQUOI LE TRACER
Création / renouvellement de consentement	Prouver que le client a autorisé, et jusqu'à quand
Lecture de comptes (succès)	Démontrer que l'accès respectait le périmètre
Lecture refusée (401/403)	Révéler une tentative hors droits — signal d'alerte
Révocation	Établir la date à partir de laquelle plus rien ne devait être lu
Expiration automatique	**Prouver que l'arrêt n'était pas une décision opportuniste**

SÉQUENCE SUIVANTE

Mais qui garde la donnée ?

On sait collecter, normaliser, stocker, servir — et même dire à qui appartient ce que l'on stocke. Reste la question qui commande toutes les autres : pendant combien de temps, sous quelles conditions, avec quelle preuve. C'est l'objet de la S4 — parce qu'un bon AISP n'est pas seulement celui qui lit bien, c'est celui qui sait aussi s'arrêter de lire.

05 · S4 · SÉCURITÉ & GOUVERNANCE

S4 - Sécurité & gouvernance

CE QUE L'ON A LE DROIT DE FAIRE DE LA DONNÉE

Sécurité & gouvernance des données

Lire les comptes de quelqu'un, c'est entrer dans son intimité financière. Un AISP ne tient pas parce qu'il sait se connecter aux banques : il tient parce qu'il sait **borner** ce qu'il lit, **limiter** ce qu'il garde et **prouver** ce qu'il a fait.

FIL ROUGE Lyam a donné son accord à MonBuddy pour lire ses deux comptes. Trois mois plus tard, il se demande : qui a accédé à quoi, pendant combien de temps, et que reste-t-il de ses données chez MonBuddy ? Cette séquence n'ajoute pas de technique : elle pose les règles qui rendent les trois précédentes acceptables.

PRINCIPE

Une asymétrie de départ défavorable

Dans un paiement, la donnée circule et disparaît. Dans l'agrégation, elle **reste**. C'est cette persistance qui crée l'essentiel du risque : une copie de l'historique bancaire d'une personne vaut cher, pour elle comme pour un

attaquant.

OBJET	PISP (JOUR 3)	AISP (JOUR 4)
Ce qui circule	Un ordre de virement	Tout l'historique de comptes
Ce qui est stocké	Peu, et peu longtemps	Beaucoup, et durablement
Valeur pour un attaquant	Faible (un ordre)	Élevée (patrimoine, habitudes, salaire)
Droit du client	**Executor un virement**	**Savoir et reprendre**

La donnée est un actif, pas un sous-produit

Un AISP qui traite ses copies de comptes comme un simple cache technique se trompe de nature. Ce sont des **données personnelles financières** : elles relèvent du RGPD en plus de la DSP2, avec les obligations de sécurité de l'article 32 (chiffrement, minimisation, journalisation).

ENJEU 1

Le consentement n'est pas une case à cocher

En DSP2, le consentement AIS est un objet technique : il a un identifiant, une durée, une liste de comptes, des droits précis. Le respecter, ce n'est pas « avoir un écran de consentement » : c'est faire correspondre chaque appel d'API à un droit effectivement accordé.

A **Finalité limitée**

Un consentement donné pour un budget ne couvre pas la revente de données à un assureur. Chaque usage non prévu exige un nouveau consentement explicite.

B **Portée vérifiée à chaque appel**

Le *consent store* doit être interrogé avant toute lecture : ce compte est-il dans le périmètre ? ce droit est-il encore valide ? L'absence de vérification est la faille la plus fréquente.

C **Durée bornée et renouvelée par le client**

L'AIS impose une validité limitée (90 jours en pratique). Le renouvellement doit être une action du client, jamais un prolongement silencieux décidé par l'AISP.

D **Révocation immédiatement effective**

Quand le client retire son consentement, les lectures suivantes doivent échouer — et les copies déjà stockées doivent suivre la politique de conservation.

L'anti-motif à connaître

Le consentement « captif » : un écran qui conditionne l'accès au service à l'acceptation d'usages annexes. Techniquement valide, juridiquement contestable — et très souvent relevé par les autorités de contrôle.

ENJEU 2

Durée de conservation : la question qu'on oublie

Combien de temps garder un historique bancaire agrégé ? Il n'existe pas de réponse unique : la durée découle de la finalité. Ce qui est certain, c'est qu'une durée non justifiée est un manquement — et qu'une durée infinie est indéfendable.

TYPE DE DONNÉE	BESOIN MÉTIER TYPIQUE	QUESTION DE GOUVERNANCE
Copie brute des transactions	Rafraîchissement, reprise après incident	Peut-on la supprimer dès la normalisation ?
Données normalisées	Affichage du budget, catégorisation	Quelle profondeur d'historique est utile ?
Données dérivées (scores, agrégats)	Scoring, conseil	Sont-elles encore rattachables à une personne ?
Journaux d'accès	**Audit, sécurité**	**Durée imposée par la loi, souvent supérieure aux données**

Le réflexe utile : justifier, pas maximiser

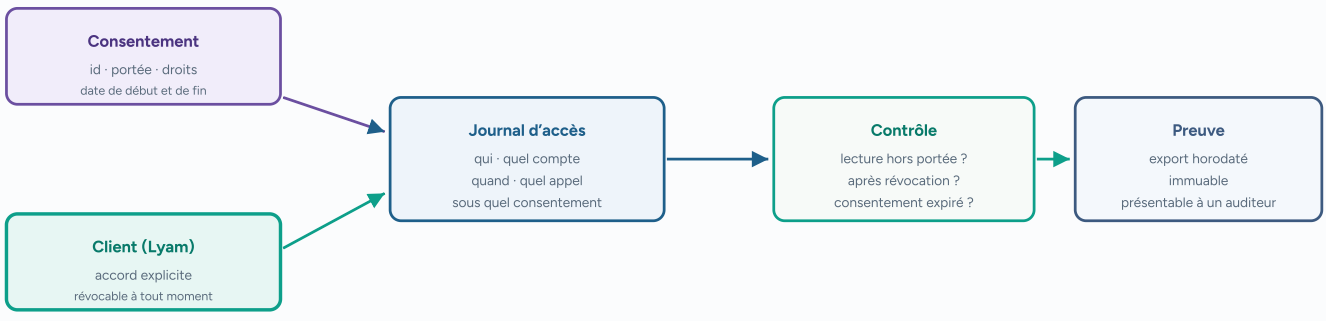
La bonne question n'est pas « combien de temps *peut-on* garder ? » mais « de quoi *a-t-on besoin*, et que se passe-t-il si on garde moins longtemps ? ». Une politique de conservation se documente, se versionne et s'applique automatiquement.

ENJEU 3

Auditabilité : pouvoir prouver, pas seulement affirmer

« Nous respectons le consentement » ne vaut rien sans preuve. L'auditabilité, c'est la capacité à reconstituer **qui** a lu **quoi**, à **quel moment**, **sous quel consentement** — et à le démontrer à un tiers qui n'a pas confiance.

Chaîne de traçabilité d'une lecture de compte



Sans journal relié au consentement, aucune des trois preuves n'est opposable : on affirme, on ne démontre pas.

Ce qu'il faut journaliser

Identifiant du consentement, comptes lus, horodatage, résultat (succès, refus, erreur), identité de l'appelant. Pas les données elles-mêmes : le journal dit *qui a lu*, pas *ce qui a été lu*.

Ce qui rend un journal inutile

Un journal réinscriptible, non horodaté de façon fiable, ou qui ne relie pas la lecture au consentement. Un audit doit pouvoir répondre en minutes, pas en semaines.

ENJEU 4

Responsabilité légale : qui répond de quoi ?

Quand un incident survient, la question n'est pas seulement « quel est le bug ? » mais « qui porte la responsabilité ? ». En Open Banking, elle se partage entre la banque, le TPP et le client — et cette répartition est écrite dans les textes.

ACTEUR	CE DONT IL RÉPOND	CE QU'IL NE PEUT PAS INVOQUER
Banque (ASPSP)	Disponibilité et performance de ses interfaces	« L'API était lente » pour ne pas corriger
TPP (AISP)	Usage conforme du consentement, sécurité des données	La faute de la banque pour justifier une fuite
Client	Confidentialité de ses identifiants de SCA	Le fait qu'un TPP agréé ait mal utilisé ses droits
Autorité	**Contrôle, sanction, retrait d'agrément**	—

Le piège de la sous-traitance

Un AISP qui délègue son stockage à un prestataire cloud reste **responsable** du traitement vis-à-vis du client. Le contrat avec le sous-traitant protège juridiquement, il ne transfère pas la responsabilité.

SYNTHÈSE

Quatre enjeux, un même principe

Consentement, conservation, auditabilité, responsabilité : les quatre ne sont pas des chapitres séparés. Chacun rend le suivant possible, et l'absence d'un seul suffit à ruiner les trois autres.

ENJEU	QUESTION POSÉE	RÉPONSE MINIMALE ATTENDUE
Respect du consentement	Ai-je le droit de lire ça ?	Vérification à chaque appel
Durée de conservation	Combien de temps puis-je garder ?	Durée justifiée par la finalité
Auditabilité	Puis-je le prouver ?	Journal horodaté relié au consentement
Responsabilité	**Qui répond si ça casse ?**	**Rôles écrits et testés**

Références

DSP2 art. 66-67 (accès et consentement AISP) ; RTS EBA 2018/389 art. 5 (accès récurrent), 10-13 (sécurité) et 36 (disponibilité) ; RGPD art. 5 (minimisation, limitation de conservation), 6 (base légale), 17 (effacement), 28 (sous-traitance) et 32 (sécurité du traitement) ; lignes directrices EBA sur la SCA.

CLÔTURE DU JOUR 4

Agréger, c’est assumer

Le Jour 4 a posé trois compétences : comprendre ce qu’est l’AIS, décrire son flux, et construire l’architecture qui le rend fiable. La Sécurité ajoute le cadre qui rend ces trois acceptables : un AISP qui lit les comptes de Lyam n’est pas seulement un bon ingénieur, c’est un **gardien de données personnelles**. C’est cet équilibre — service réel, droits réels — qui fait de l’Open Banking une infrastructure de confiance.